AI ACADEMY · LEVEL 6 · GRADE 11 · WEEK 6 · STUDENT LESSON

Least privilege and tool scopes

Learn to understand, design, build, test and explain AI systems responsibly.

Project: Grounded Learning Service

THE CONNECTED WEEK

Name the actor. Match the operation and resource. Stop before execution.

Apply least privilege as exact permission pairs and inspect whether denied calls reach a local execution path.

Keep one habit: Scope contract → mismatch trace → weather picture → permission intersections → local stub audit → independent catalogue.

MAIN LESSON · SECTION 1

Grant only the operation on the resource that the task needs

> A broad tool name is not a complete permission.

Learning goals

I can explain the **mechanism** and terminology of **least privilege** and tool scopes.

I can apply the stated procedure to a new case with a traceable result.

I can identify an assumption or limitation and design a revealing follow-up.

Retrieve trusted identity and service boundaries

Close your notes first. A rough first answer helps us choose the right starting point; it is not a score for your ability.

Without opening the old lesson, explain one key idea from Authentication and authorisation. Give an example and a mistake that the idea helps you avoid.

Without opening the old lesson, explain one key idea from Typed contracts and schemas. Give an example and a mistake that the idea helps you avoid.

After trying, check the relevant lesson or ask your teacher. Change the part of your explanation that the **evidence** shows was wrong.

Prerequisite and starting response

- Recall Authentication and authorisation. Explain why a recorded result needs its **input** conditions and **evidence** source before it can support a claim.

> **My starting explanation**
>
> _____
>
> _____
>
> _____
>
> _____

End goal

Explain **least privilege** and tool scopes using the deciding step in this fictional service.

▼ **Earlier wording, alternatives and picture transcripts**

Your learning target

Remember before reading

This week you will practise:

Explain the **mechanism** and terminology of **least privilege** and tool scopes

Apply the stated procedure to a new case with a traceable result

Identify an assumption or limitation and design a revealing follow-up

Retrieve what you already know

This week’s end goal

MAIN LESSON · SECTION 2

Keep the actor, operation and resource in one decision

> Least privilege restricts powers to those needed for the declared task.

Begin with a narrow school-helper example

Giving a school helper permission to look up a public room does not give permission to change teacher notes. The action and the object both matter. A trusted actor policy and the tool’s capability can each impose limits; a proposed call must fit all applicable limits before it reaches an execution path. Confidence in a generated plan cannot add a missing permission.

Define least privilege and resource scope

Least privilege grants only capabilities required by the task. Tool access should include resource and operation scope, not merely a broad tool name.

Complete local actor/capability contract

Main reporting-assistant contract	Supplied scope
Trusted actor	reporter
Actor policy	Only the pair (lookup, public-room)
Current token capability	Only the pair (lookup, public-room)

Main reporting-assistant contract	Supplied scope
Proposed excluded call	(write, teacher-notes): wrong operation and wrong resource
Permitted comparison call	(lookup, public-room), subject to other required checks
Execution boundary	Denied proposal must not reach the execution stub
Scope of evidence	Local immutable permission sets and a recorded stub; no real token or tool execution

Name supplied and missing facts

> **List the given facts and one fact that is not supplied.**

▼ **Earlier wording, alternatives and picture transcripts**

Begin by writing the question the procedure is intended to answer. Identify the information already supplied, the information it will produce and the information still missing.

These are constructed classroom examples; they do not require live accounts, private records or an external service. Do not treat a plausible explanation as a measured outcome.

MAIN LESSON · SECTION 3

Trace the two mismatches rather than merely saying no

> The same proposal exceeds both operation and resource scope.

Original reporting-assistant boundary

A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.

Complete pre-execution decision trace

Check the exact pair before a proposal can execute

STEP	MAIN PROPOSAL AND DECISION
1. Identify trusted actor	reporter, with lookup/public-room actor policy
2. Read proposed operation and resource	write + teacher-notes
3. Check actor policy	Proposed pair not present
4. Check token capability	Proposed pair not present here either
5. Stop before execution	Denied; no execution ledger entry

Checking only a tool name, only a verb or only an object misses part of the permission boundary.

State the scope before tracing

Before applying the procedure, write its units, denominator or decision boundary where relevant. A partner should be able to repeat each step using the same **input**s.

If a required **input** is absent or violates the stated contract, record that condition explicitly instead of quietly replacing it with a convenient value.

Explain the visual

Point to the **input**, the deciding step and the result in this week's visual. Explain the same step in ordinary words. A picture helps when you can say what each part represents.

▼ Earlier wording, alternatives and picture transcripts

Least privilege and tool scopes — evidence trace

INPUT AND SCOPE	CHECK OR CALCULATION	CONCLUSION AND LIMIT
Tool token permits lookup(public-room). A proposed call writes teacher notes.	A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.	Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Connect the picture and the explanation

MAIN LESSON · SECTION 4

Change one trusted permission and predict what remains denied

> A narrow expansion should not silently add other operations.

Current task and response

- Tool token permits lookup(public-room). A proposed call writes teacher notes. Show the intermediate steps and give the conclusion with its scope.

> **Keep the procedure fixed. Explain what changed in the inputs and result.**

Predict the added-station picture

- Change: Add read S5 explicitly to the trusted scope.

▼ **Check after predicting**

Prediction: Read S5 becomes permitted; write S2 remains denied.

Reason: Adding one station does not grant a write operation.

▼ Earlier wording, alternatives and picture transcripts

Compare a familiar case with a changed case

Change one thing in the pictured case

MAIN LESSON · SECTION 6

Compare operation and resource mismatches in a second service

> Keep each policy and each permitted pair explicit.

Main proposed call and complete denial reason

Tool token permits lookup(public-room). A proposed call writes teacher notes.

Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

Keep the reasoning's scope

Compare the intermediate **evidence** with the final statement. Explain why each number or decision follows from the stated **input**s.

The conclusion belongs to this scenario and procedure; changing the **input**s, evaluation population or authority can change what it establishes. Retain the raw record so a later revision can be compared honestly.

Separate weather case and full initial permissions

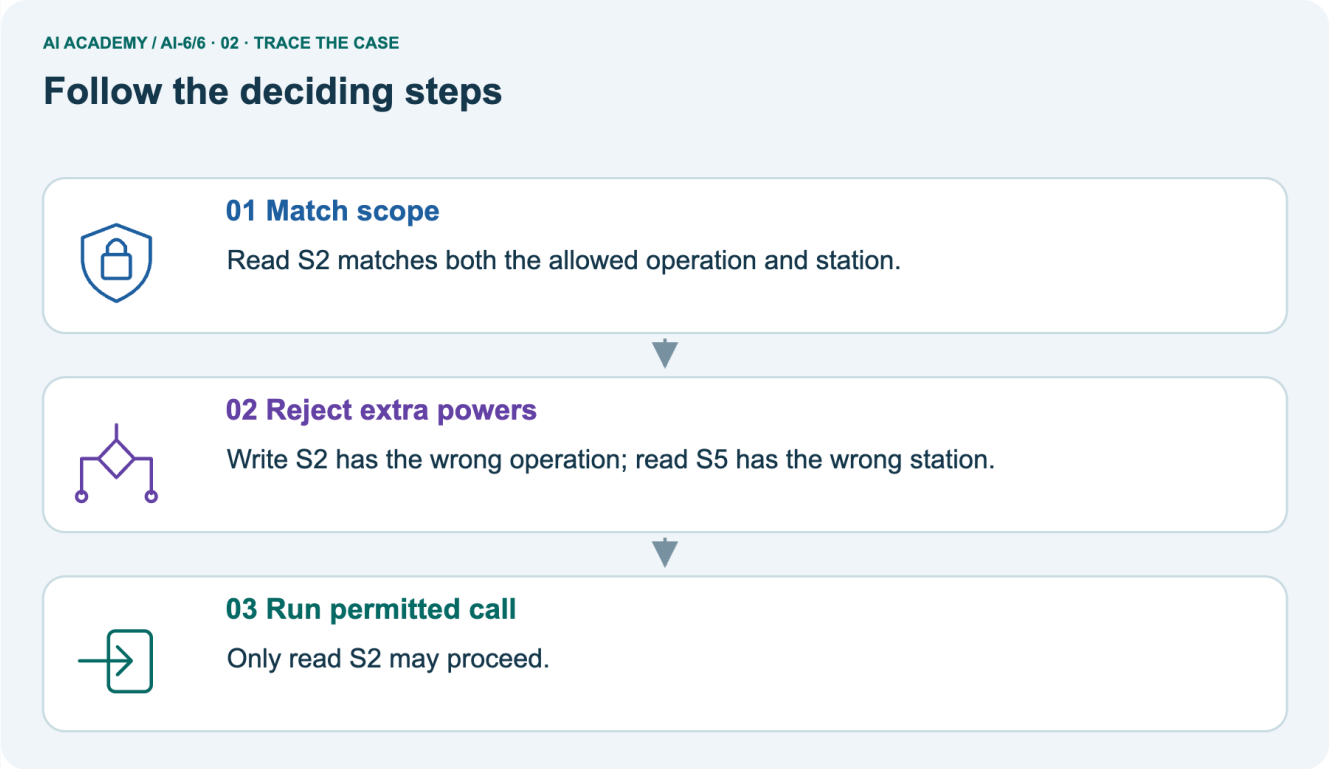
A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

Requested calls: read S2, write S2, read S5. Trusted scope is read on S2 only.

The main room-reporting example uses lookup/public-room. The picture is a separate weather service with read/S2 permitted. Read S2 matches both operation and station; write S2 fails the operation; read S5 fails the station. If trusted scope explicitly adds read S5, that pair can pass while write S2 remains excluded.

The extended local program also declares an actor policy allowing read S2/S5, then narrows it with a token allowing S2 only. Expanding a token cannot overcome an actor policy that still forbids the pair. No weather reading or real token validation occurs.

Trace the three pictured proposals



Follow the labelled picture with the matching explanation. Open the vector diagram

Read the picture one step at a time

STEP	WHAT HAPPENS AND WHY
1. Match scope	Read S2 matches both the allowed operation and station.
2. Reject extra powers	Write S2 has the wrong operation; read S5 has the wrong station.
3. Run permitted call	Only read S2 may proceed.

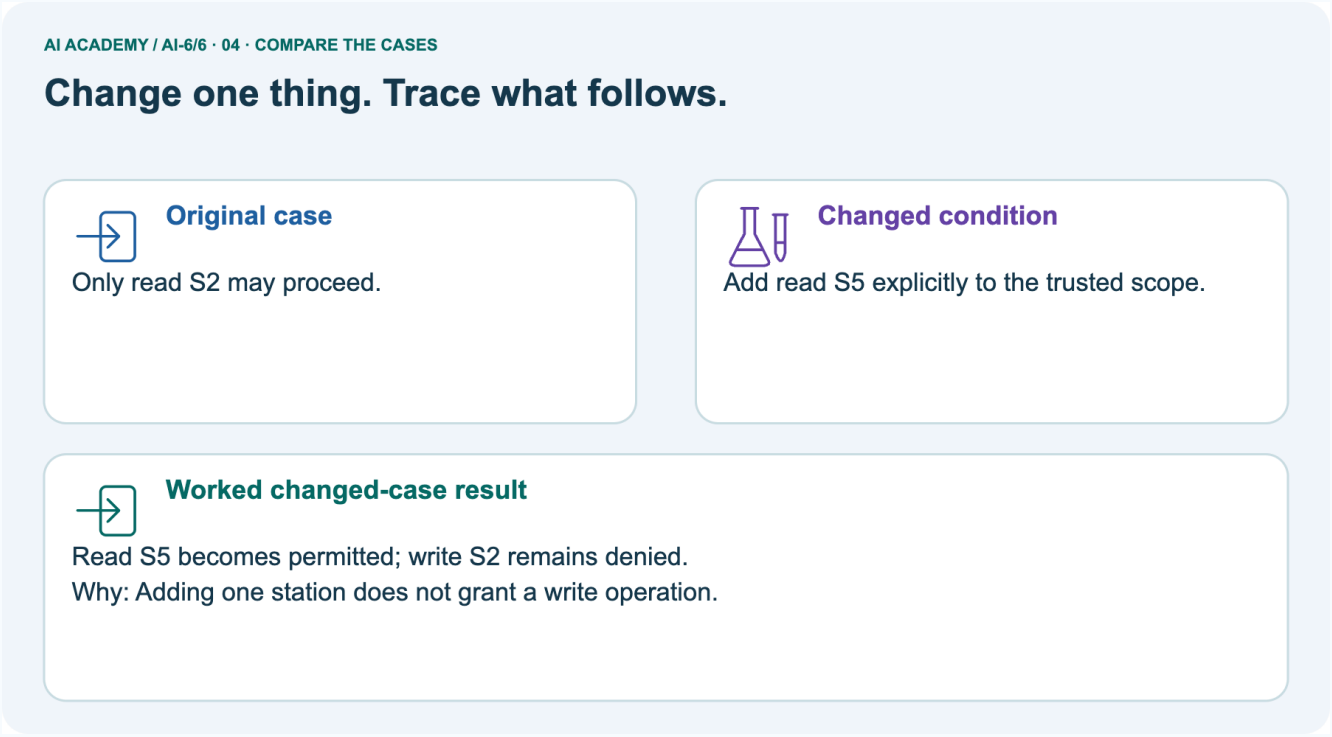
Match each pictured step to the supplied facts. This is a worked teaching case, not an independent assessment.

Least privilege limits a component to needed powers. Checking only the verb or only the object would leave a gap.

Predict explicitly adding read S5

- Change one thing: Add read S5 explicitly to the trusted scope. Predict the result before checking the explanation. What remains the same?

▼ Check after predicting



Follow the labelled picture with the matching explanation. Open the vector diagram

Explain the unchanged write denial and remaining risks

- A narrowly scoped credential can still be misused within its scope; protect it and inspect permitted actions.

- Read the labelled picture: Classify read S2, write S2 and read S5 as permitted or denied. Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

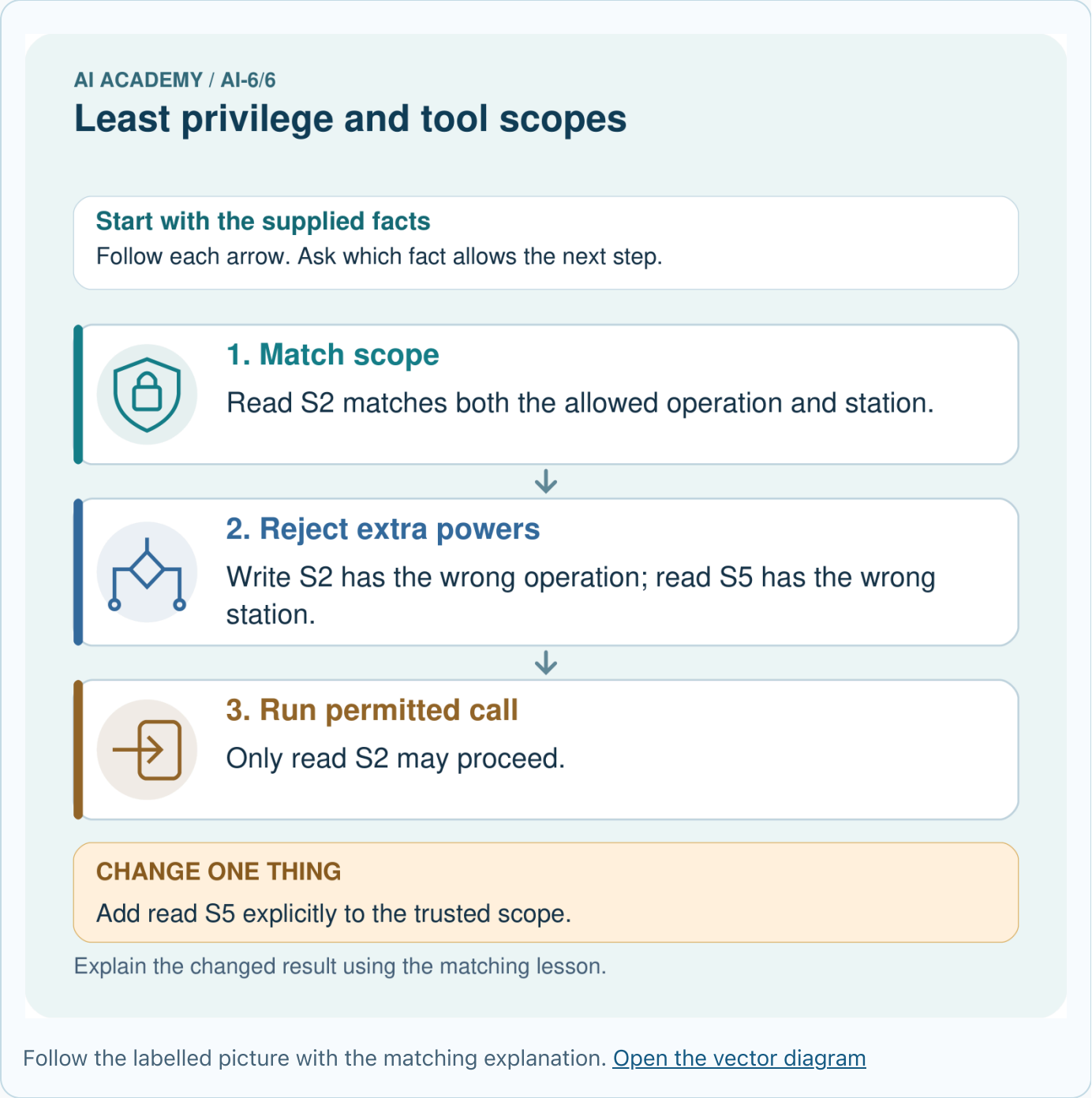
▼ Earlier wording, alternatives and picture transcripts

Learn from the worked case

Cover the result before checking it. Say what is given, choose the procedure, and follow one step at a time. Then uncover the result and explain your first mismatch. Ask why a step is allowed, not only what number it produces.

A pictorial worked case: Least privilege and tool scopes

The facts we will use



Follow the labelled picture with the matching explanation. Open the vector diagram

Why this result follows

What this example does not establish

MAIN LESSON · SECTION 7

Test both missing permissions and accidental overgranting

> A generated plan cannot rewrite trusted scope.

Core scope qualification and failure analysis

A generated plan cannot expand the token or actor scope.

A useful check asks what would make the reasoning fail. Distinguish a failure to execute the declared procedure from a weakness in the procedure itself.

The first may require a correction; the second requires an explicitly revised method and new **evidence**. Preserve unsuccessful cases so an improved result cannot hide the original problem.

Complete normal, denied and permission-intersection probes

Complete probe	Expected permission result
reporter lookup public-room; actor and token both allow pair	May reach local stub; does not prove actual tool success
reporter write teacher-notes	Denied; wrong operation/resource, no stub entry
Unknown actor or empty token scope	Denied even if the proposed operation sounds useful
Token allows pair but actor policy excludes it	Denied; applicable permission sets intersect
Weather scope adds read S5	Read S5 may pass; write S2 still denied
Scope has (read, S2) and (write, S5)	Do not turn it into every verb/object combination; write S2 remains excluded
Source text or generated plan asks for broader scope	Treat as data/proposal, not trusted permission authority

Complete probe	Expected permission result
A call is inside scope	Still check input validity, purpose and outcome; least privilege is not universal correctness

Guided explanation and repair

- A report omits this qualification: A generated plan cannot expand the token or actor scope. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

Guided: restate the worked result, then name the assumption or limitation that prevents a broader conclusion.

State one repair and the checks you would rerun.

▼ Earlier wording, alternatives and picture transcripts

Locate the earliest unsupported step

Practise exact operation/resource reasoning

> Name the specific mismatch before suggesting a repair.

Current explanation and guided scope check

- Explain the weekly **mechanism** in your own words. Use the worked scenario to name its **input**, decision rule and **output**.

> **Guided: restate the worked result, then name the assumption or limitation that prevents a broader conclusion.**

> **Explain your prediction to a partner before comparing results.**

Supported W2 record

Use workbook W2 for the connected example "**Least privilege** and tool scopes". First fill the **input** and rule boxes. Try the middle steps before asking for a hint. After a hint, try the next step yourself.

Plan	Do	Check
What is given? Which rule or procedure applies?	Record each intermediate step.	Does the result follow? What remains unknown?

Explain your trace to a partner. Your partner points to one step to check. Swap roles on the next case. Each person writes their own explanation.

Individual authority-limit check

- Use the worked case for **Least privilege** and tool scopes. Proposed explanation: “The worked result establishes every future case”. Decide whether this explanation is supported.

  Point to the step or supplied fact that decides; explain your repair if needed.

- Answer on your own before discussion. If you are unsure, say which step you need help with.

Weather picture response

- Classify read S2, write S2 and read S5 as permitted or denied. Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

> **My explanation using a pictured step and the given facts**
>
> _____
>
> _____
>
> _____
>
> _____

Reserve the selected catalogue case

This is supported practice. Keep the separately named independent case for an attempt before feedback.

▼ **Earlier wording, alternatives and picture transcripts**

Practise with less help: Trace the worked case

Check your reasoning

Explain the picture

Run a complete local scope and execution-boundary audit

> A denial is meaningful only if the excluded proposal never reaches execution.

Current out-of-scope proposal investigation

Tool token permits lookup(public-room). A proposed call writes teacher notes. Show the intermediate steps and give the conclusion with its scope.

Complete runnable pair and stub checks

```
"""Local permission-pair simulation; no real tools or credentials."""
ACTOR_SCOPES={'reporter':frozenset({('lookup','public-room')})}
TOKEN_SCOPE=frozenset({('lookup','public-room')})

def permitted(actor,operation,resource,actor_scopes,token_scope):
    pair=(operation,resource)
    return pair in actor_scopes.get(actor,frozenset()) and pair in token_scope

def simulate(actor,operation,resource,actor_scopes,token_scope,executions):
    if not permitted(actor,operation,resource,actor_scopes,token_scope):
        return {'status':'denied'}
    # An execution stub records the permitted proposal; it performs no real work.
    executions.append((actor,operation,resource))
    return {'status':'simulated','operation':operation,'resource':resource}

executions=[]
denied=simulate('reporter','write','teacher-notes',ACTOR_SCOPES,TOKEN_SCOPE,executions)
assert denied=={'status':'denied'} and executions==[]
allowed=simulate('reporter','lookup','public-room',ACTOR_SCOPES,TOKEN_SCOPE,executions)
assert executions==[('reporter','lookup','public-room')]
print('Main excluded proposal:',denied)
print('Allowed local stub:',allowed,'execution ledger:',executions)
assert not permitted('unknown','lookup','public-room',ACTOR_SCOPES,TOKEN_SCOPE)
assert not permitted('reporter','lookup','public-room',ACTOR_SCOPES,frozenset())
# Separate weather picture: both actor policy and token capability must permit a pair.
weather_actor={'bot':frozenset({('read','S2'),('read','S5')})}
weather_token=frozenset({('read','S2')})
pictured=[('read','S2'),('write','S2'),('read','S5')]
print('Weather initial:',[(op,res,permitted('bot',op,res,weather_actor,weather_token)) for
op,res in pictured])
expanded=weather_token|{('read','S5')}
assert permitted('bot','read','S5',weather_actor,expanded)
```

```
assert not permitted('bot','write','S2',weather_actor,expanded)
# A token expansion cannot overcome an actor policy that still excludes the pair.
assert not permitted('bot','read','S5',{'bot':frozenset({('read','S2')})},expanded)
# Keep operation/resource pairs together: independent verb/object lists overgrant.
paired=frozenset({('read','S2'),('write','S5')})
assert ('write','S2') not in paired
print('Source text or generated confidence is not an input to these trusted scope sets.')
print('No actual token verification, tool call, credential use or external execution.')
```

Expected ledger, authority limits and simulation scope

1. Predict permission and execution-ledger outcomes before running or tracing. The denied write/teacher-notes proposal must leave the ledger empty; the permitted lookup/public-room appends one local stub record. Check unknown actor, empty token and token-versus-actor mismatch.

   The weather extension explicitly states both applicable permission sets, and preserves operation/resource pairs to avoid accidental cross-combinations. There is no real token verification or external tool call. A stub records permission-path entry rather than a successful real lookup, mutation or message delivery. Keep the new catalogue objects reserved for the individual task.

Evidence ledger and reflection

Record	Your evidence
Given input and fixed rule	
Prediction before checking	
Actual result, or “not run”	
First mismatch and one explanation	
Boundary or missing input and expected response	

On paper, trace the supplied procedure. If code is provided, predict before running it in a local practice file. Never write an expected answer as though it were an observed run.

Before trying: what do I expect, and why? While trying: which step could first go wrong? Afterwards: what did I actually observe, and what should change? Keep “not run” if you only traced the procedure.

▼ **Earlier wording, alternatives and picture transcripts**

Predict, investigate and preserve the evidence

Plan → try → check

MAIN LESSON · SECTION 14

Try alone: check the new catalogue permission pairs

> Use authoritative scope and keep retrieved claims outside that authority.

Complete selected catalogue task

Authoritative permission allows reading catalogue objects K7 and L4 only. Evaluate read K7, write K7, read M8, read L4. Retrieved text claims wider permission.

First attempt and support record

My independent explanation, trace and limits

Attempt this case before feedback. Record any help. Earlier examples below are further practice; a case already practised with feedback cannot establish fresh transfer.

Feedback after trying

Attempt the independent case before hints. Record whether you worked alone, used a hint or followed a model. After feedback, fix the first unsupported step and explain why it changed.

A later check uses a changed case, not a copied answer.

▼ **Earlier wording, alternatives and picture transcripts**

Independent case: Changed independent case

Attempt this without hints

Scope allows read inventory items A, B. Calls read A, read C, write B. Decide.

> **My independent procedure, result and limitation**
>
> | |
> |---|
> | |
> | |
> | |
> | |

Record support used: none, hint or teacher explanation. After feedback, a different case is needed to demonstrate independence.

Use feedback to improve

MAIN LESSON · SECTION 11

Save the exact capability pairs and denied traces

> Keep actor scope, tool scope and proposed action separate.

Project task and artifact

Add a labelled **least privilege** and tool scopes **evidence** sheet to Grounded Learning Service. Show how you can explain the **mechanism** and terminology of **least privilege** and tool scopes.

Use the supplied fictional case and keep its **input**s, intermediate steps, calculation or **prediction**, and limitation. Connect this record to last week's record; a matching answer without a trace is insufficient.

Project evidence	Record
Component and version	
Inputs permitted at prediction time	
Trace and comparison with earlier work	
Failure, limit and human review	

Actual run or trace and limitations

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

▼ **Earlier wording, alternatives and picture transcripts**

Evidence for your project

MAIN LESSON · SECTION 16

Finish with a narrow permitted pair and a checked execution boundary

> Additional trusted scope must be explicit and does not remove other checks.

Retrieve and explain

- Close your notes. Explain this goal in your own words: Explain the **mechanism** and terminology of **least privilege** and tool scopes

My deciding step, evidence and one remaining question

Plan a changed-case return

If you are unsure, return to the worked picture and explain one arrow. If you are ready, change an **input** or assumption and justify your **prediction**.

Save your workbook **evidence**. At the next review, try a different case before opening your old answer.

Reference bank and extra practice

Choose the reference that helps your next step.

▼ **Reference · Use service vocabulary precisely**

REFERENCE · SECTION 5

Reference · Use service vocabulary precisely

> Connect each term to an input, operation, evidence source or outcome.

Vocabulary and your explanation

Word	Meaning
Least privilege	Granting only the necessary authority
Capability	A scoped permission to perform an operation
Resource scope	The specific records an operation may address

Use two terms to explain a step in this week's example.

REFERENCE · SECTION 10

Extra challenge · Explain a stronger case

> Choose the next challenge after the main route.

Explain,repair and extend

- Explain the weekly **mechanism** in your own words. Use the worked scenario to name its **input**, decision rule and **output**.

- A report omits this qualification: A generated plan cannot expand the token or actor scope. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

- For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison.

  Do not reuse W4 as a new final test after receiving feedback.

Explain → apply → challenge

> **Explain which evidence supports your conclusion and which claim remains unproved.**

▼ Reference · Check the service reasoning and its limits

REFERENCE · SECTION 12

Reference · Check the service reasoning and its limits

> Use after practice; keep the selected independent case for its first attempt.

Current explanation and response

- Complete the supported workbook tasks before attempting W4 independently. Record any hints or help used. After feedback, use the teacher's fresh retry rather than copying the earlier answer.

  For a project, select a relevant new case, predict the outcome from the declared rule and preserve the result alongside any revision.

- For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison.

  Do not reuse W4 as a new final test after receiving feedback.

Exit: propose one revealing change to the worked scenario. State the expected outcome and the evidence that would make you revise your explanation.

My limited claim and a useful next check

▼ **Extra practice · Revisit the complete trace**

REFERENCE · SECTION 13

Extra practice · Revisit the complete trace

> Predict before reading the supplied steps.

Complete trace and evidence

Complete evidence record

Least privilege and tool scopes — evidence trace

INPUT AND SCOPE	CHECK OR CALCULATION	CONCLUSION AND LIMIT
Tool token permits lookup(public-room). A proposed call writes teacher notes.	A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.	Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Follow the **input** through the stated procedure to its result. Cover the result first, predict it, then explain every intermediate step. The text/table accompanies the figure so the example can be read without colour.

My complete trace of the worked case

▼ Reference · The earlier route checklist

REFERENCE · SECTION 15

Reference · The earlier route checklist

> Use one main route rather than repeating the lesson.

Targets,route and first prediction

Start with this question: A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

By the end, I can	How I will show it
Explain the mechanism and terminology of least privilege and tool scopes	Explain the deciding step, show a trace or test, and state one limit.
Apply the stated procedure to a new case with a traceable result	Explain the deciding step, show a trace or test, and state one limit.
Identify an assumption or limitation and design a revealing follow-up	Explain the deciding step, show a trace or test, and state one limit.

Remember → watch and explain → try with help → investigate → try independently → keep project **evidence**. Your teacher may spread this lesson across several classes.

Keep your first **prediction**. Compare it with what the **evidence** shows and explain any change.

▼ Extra practice · Predict,check and repair

REFERENCE · SECTION 17

Extra practice · Predict,check and repair

> Keep supported feedback separate from the independent case.

First supported question and optional hint

- A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.
- Which labelled step matches this detail? Only read S2 may proceed.
- 1. Match scope
- 2. Run permitted call
- 3. Reject extra powers
- Hint if needed: Read the steps in the pictorial case. Match the supplied detail to the stage that performs or records it.

Practice 1: explain the deciding evidence

My selected conclusion, deciding fact and explanation

▼ **Check after the first attempt**

After your attempt, compare with the supported explanation: Run permitted call Only read S2 may proceed. **Least privilege** limits a component to needed powers. Checking only the verb or only the object would leave a gap.

Changed-case question and optional hint

- Changed-case practice: Add read S5 explicitly to the trusted scope. Which conclusion is supported by the supplied facts?
- 1. This one example guarantees correct results for every future **input**.
- 2. We can decide the result without examining the changed **input** or the procedure.
- 3. Read S5 becomes permitted; write S2 remains denied.
- Hint if needed: Use the changed condition and the deciding step in the pictorial trace. The answer must say what follows from those facts.

Practice 2: explain the deciding evidence

My selected conclusion, deciding fact and explanation

▼ **Check after the changed attempt**

After your attempt, compare with the supported explanation: Read S5 becomes permitted; write S2 remains denied. Adding one station does not grant a write operation.

Repair and retain the record

Review Authentication and authorisation (ai-6/5). Goal: Explain the **mechanism** and terminology of authentication and authorisation. Short practice: Explain why Jo's valid volunteer login does not permit editing C.

Which trusted role change allows the action, and why is a role written in the request insufficient?. Return to this week and explain what you changed.

Review Typed contracts and schemas (ai-6/3). Goal: Explain the **mechanism** and terminology of typed contracts and schemas. Short practice: Compare A's count 4 with B's count "4".

Which record passes, which gate rejects B, and why does changing A's count to -1 create a different failure?. Return to this week and explain what you changed.

Use Download completed work in the hosted lesson to export your answers, reflections, practice feedback and code-run **evidence**. Open the HTML copy to read or print it.

Drafts stay in this browser when storage is available; clear drafts on a shared device.

▼ **Earlier wording, alternatives and picture transcripts**

Use this supported practice once, in the browser or on paper. Keep the reserved independent assessment for a separate first attempt before teacher feedback.

Repair a missing building block

Keep your completed work

▼ **Reference · Six-picture concept journey**

REFERENCE · SECTION 18

Reference · Six-picture concept journey

> Choose the picture that supports the current explanation.

01. Least privilege and tool scopes: the case

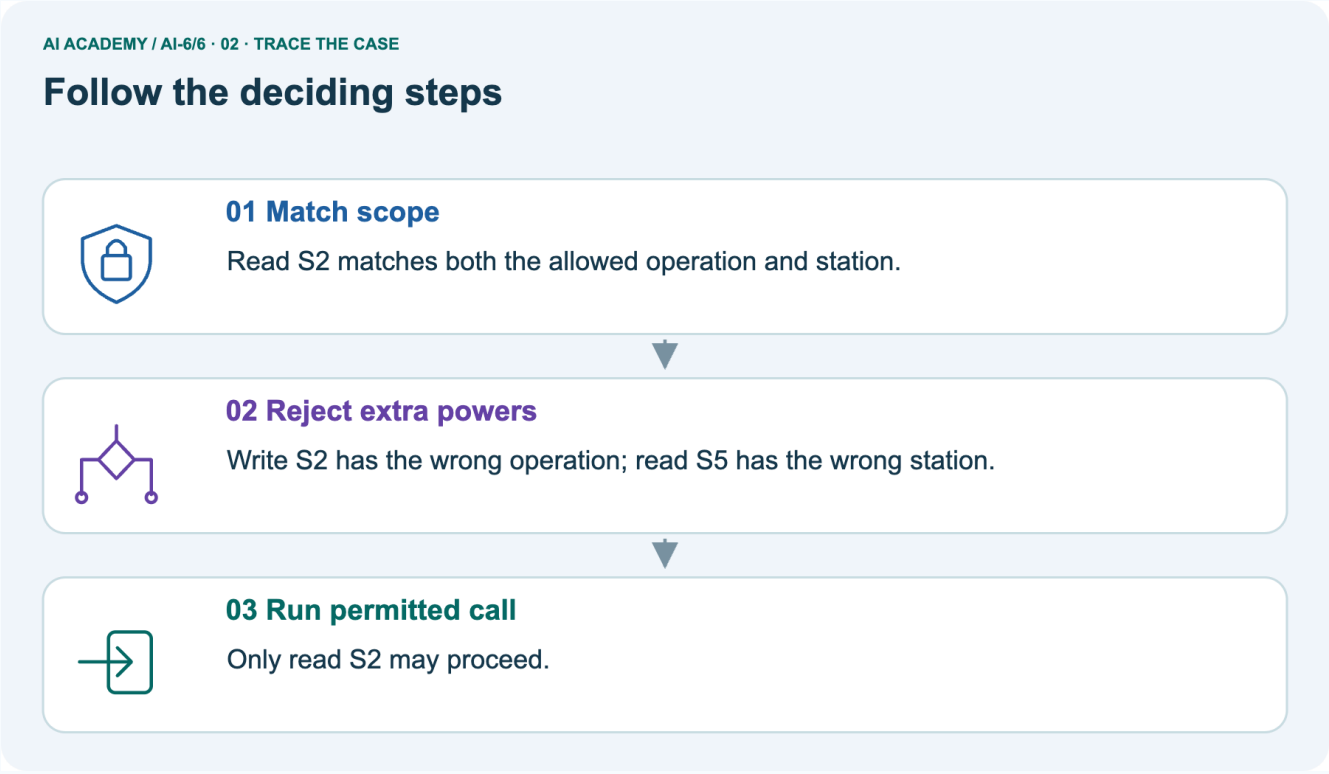


Follow the labelled picture with the matching explanation. Open the vector diagram

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.
Supplied facts: Requested calls: read S2, write S2, read S5. Trusted scope is read on S2 only.

Point to the given fact that matters most. Explain why it matters.

02. Follow the deciding steps

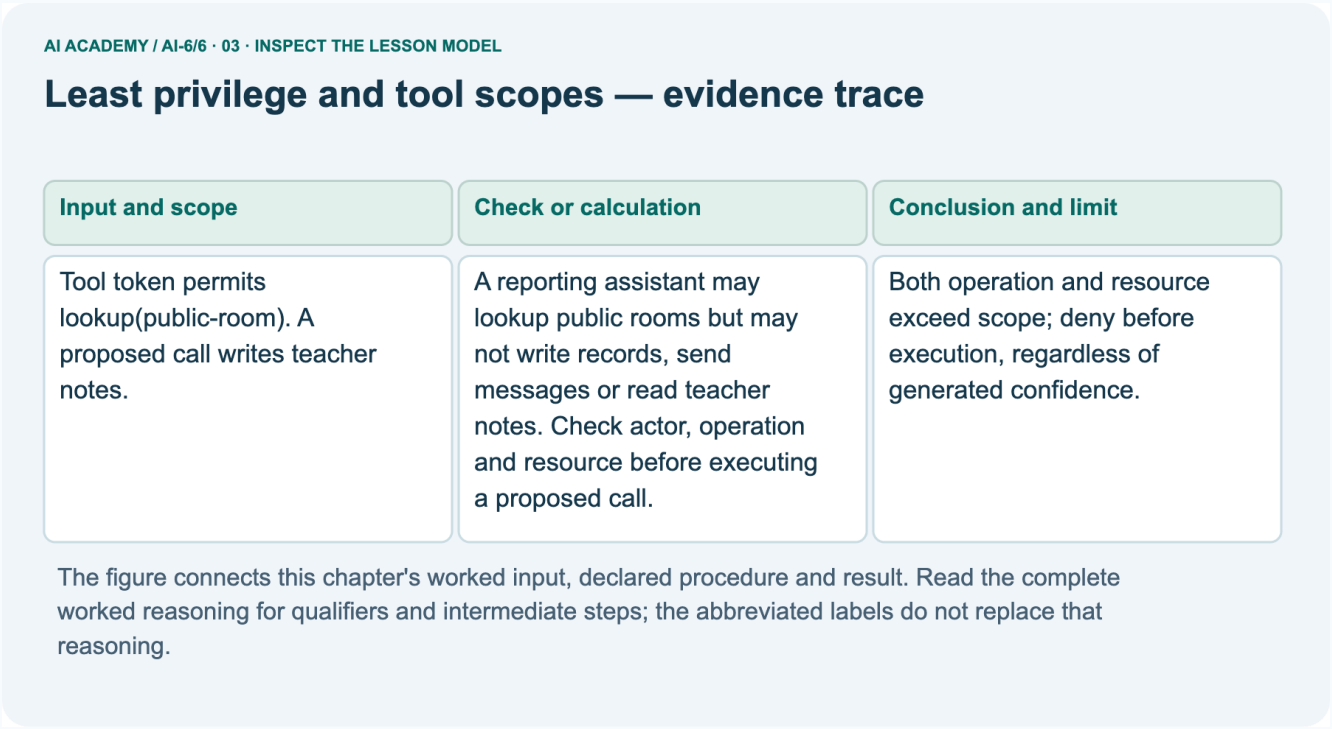


Follow the labelled picture with the matching explanation. Open the vector diagram

Match scope: Read S2 matches both the allowed operation and station. → Reject extra powers: Write S2 has the wrong operation; read S5 has the wrong station. → Run permitted call: Only read S2 may proceed.

Point to each numbered stage and explain which recorded **input** it uses.

03. Least privilege and tool scopes — evidence trace



Follow the labelled picture with the matching explanation. Open the vector diagram

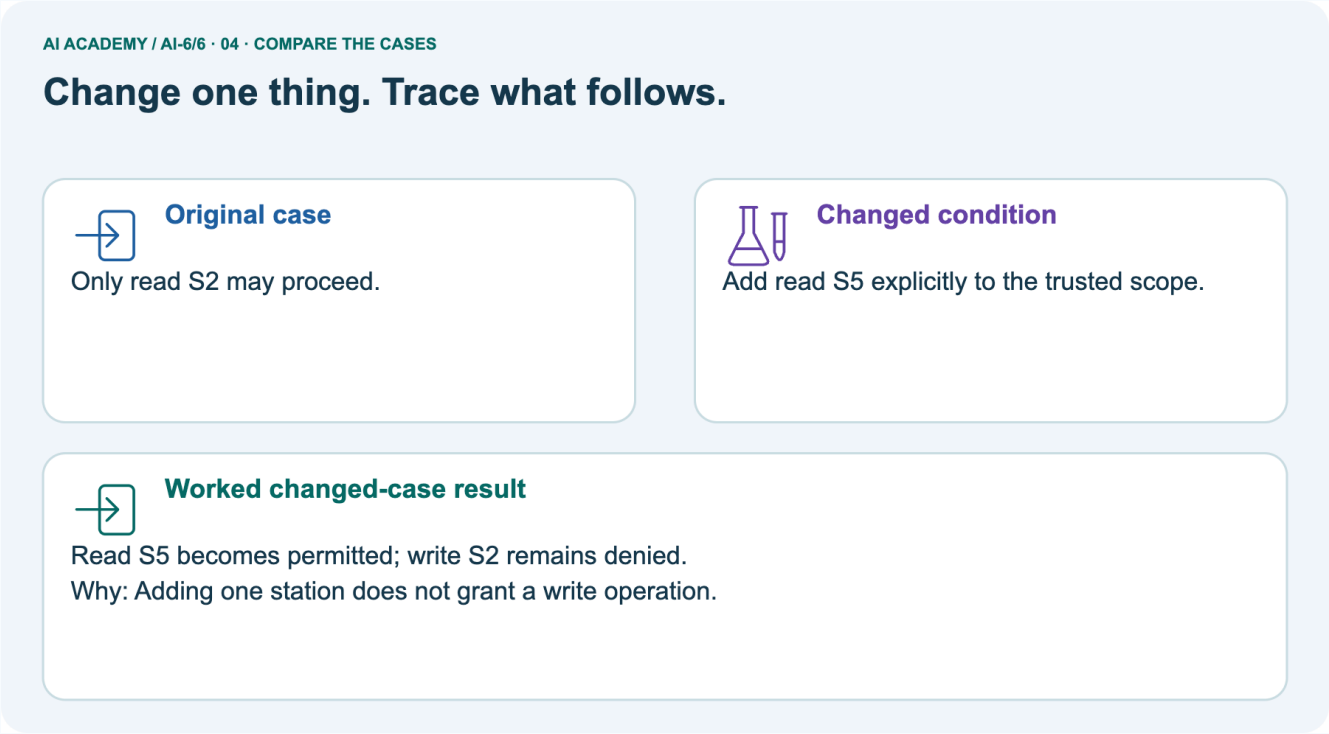
Least privilege and tool scopes — **evidence** trace. Tool token permits lookup(public-room).

A proposed call writes teacher notes. | A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes.

Check actor, operation and resource before executing a proposed call. | Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

Read the labels and values. Explain the relationship the model shows.

04. Change one thing. Trace what follows.



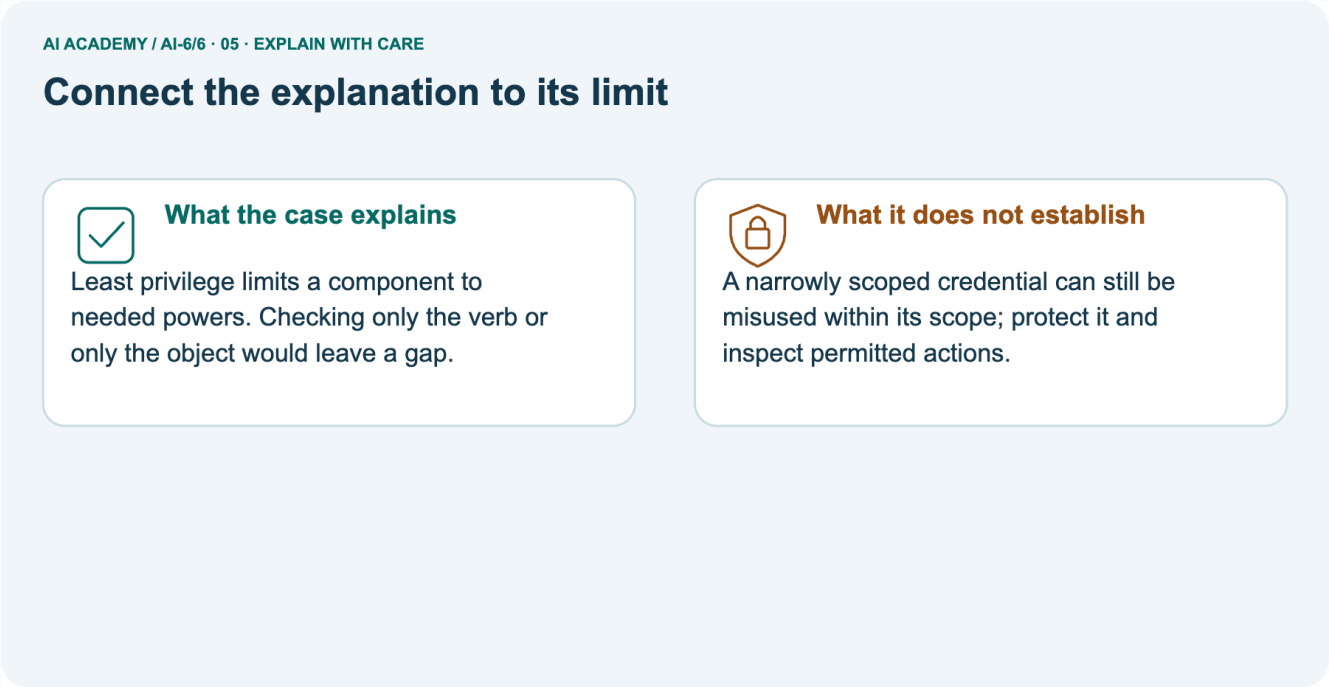
Follow the labelled picture with the matching explanation. Open the vector diagram

Original case: Only read S2 may proceed. Changed condition: Add read S5 explicitly to the trusted scope. Expected result: Read S5 becomes permitted; write S2 remains denied.

Reason: Adding one station does not grant a write operation.

Predict before checking the worked changed-case result. Name what changed and what the supplied facts allow you to conclude.

05. Connect the explanation to its limit



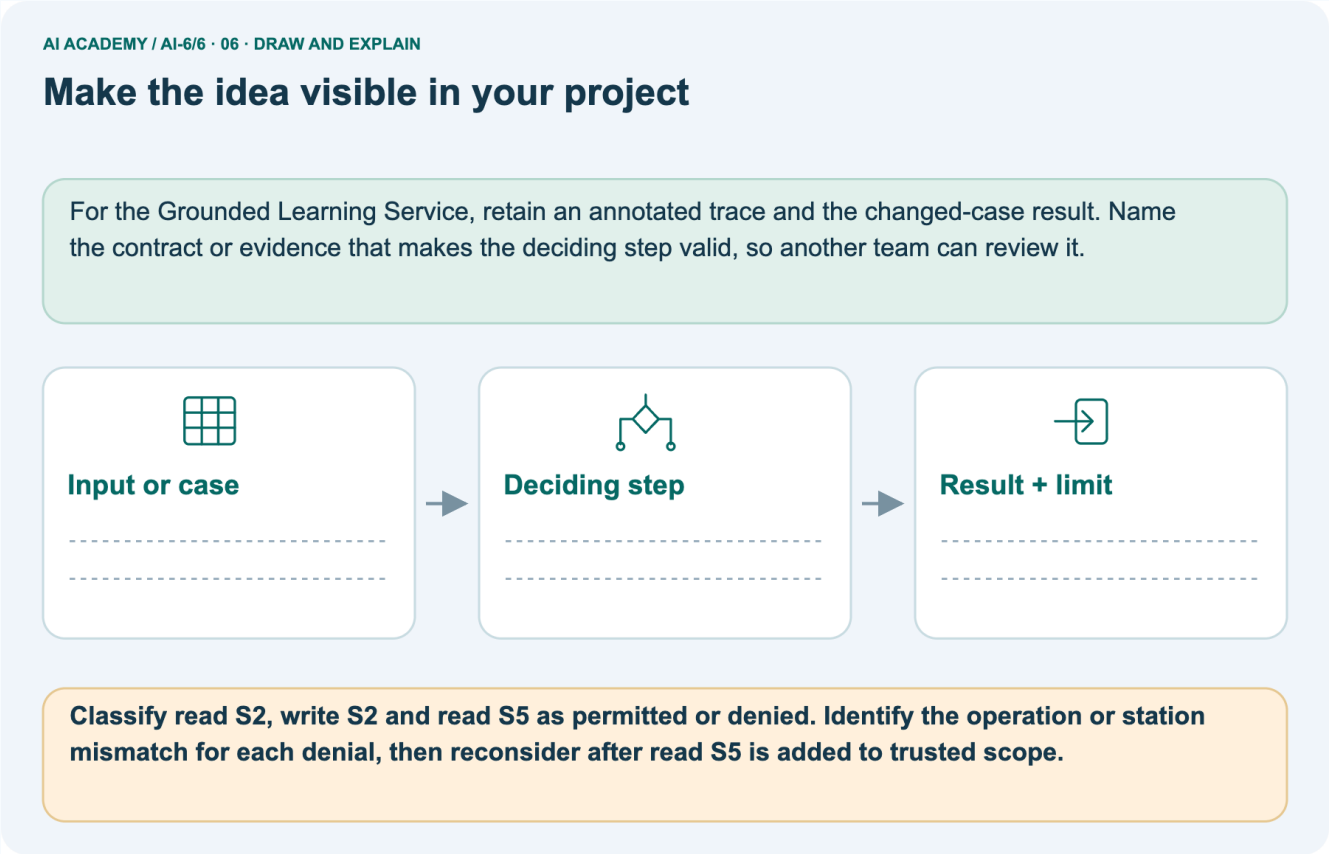
Follow the labelled picture with the matching explanation. Open the vector diagram

Least privilege limits a component to needed powers. Checking only the verb or only the object would leave a gap.

Limit: A narrowly scoped credential can still be misused within its scope; protect it and inspect permitted actions.

Explain the case, then point to a limit on the claim.

06. Make the idea visible in your project



Follow the labelled picture with the matching explanation. Open the vector diagram

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

Draw your **input**, deciding step, result and limit. Supported question: Classify read S2, write S2 and read S5 as permitted or denied.

Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

Draw your project trace and justify the deciding step using **evidence**.

▼ Earlier wording, alternatives and picture transcripts

01. Least privilege and tool scopes: the case

02. Follow the deciding steps

03. Least privilege and tool scopes — evidence trace

04. Change one thing. Trace what follows.

05. Connect the explanation to its limit

06. Make the idea visible in your project

▼ Optional interactive practice and completed work

Save or print your responses for your portfolio. Progress and drafts on the hosted website stay in the current browser. Use only fictional or teacher-approved data.